

Lab 2: Logs de Windows: Event Log i PowerShell

Detecció d'amenaçes

GEI | FIB | Curs 2026/2027



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

Facultat d'Informàtica de Barcelona



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

Facultat d'Informàtica de Barcelona

Detecció d'amengaces

Assignatura amb 22 hores de laboratori corresponent a l'especialitat:

Tecnologies de la informació

Incloua en el:

Grau en Enginyeria Informàtica



Sobre mi

- **MANEL RODERO**

- Administrador de Sistemes, [Universitat Politècnica de Catalunya](#):
 - [UTGCNTIC](#) [2019 – actualitat]
 - [inLab FIB](#) [2012 – 2019]
 - LCFIB [1996 – 2012]
- Analista de Seguretat, [esCERT-UPC](#) [2013 – 2017]
- Enginyer Informàtic, [Facultat d'Informàtica de Barcelona](#) [1999]
- Contacte:
 - manel.rodero@upc.edu

S2. Logs de Windows: Event Log i PowerShell

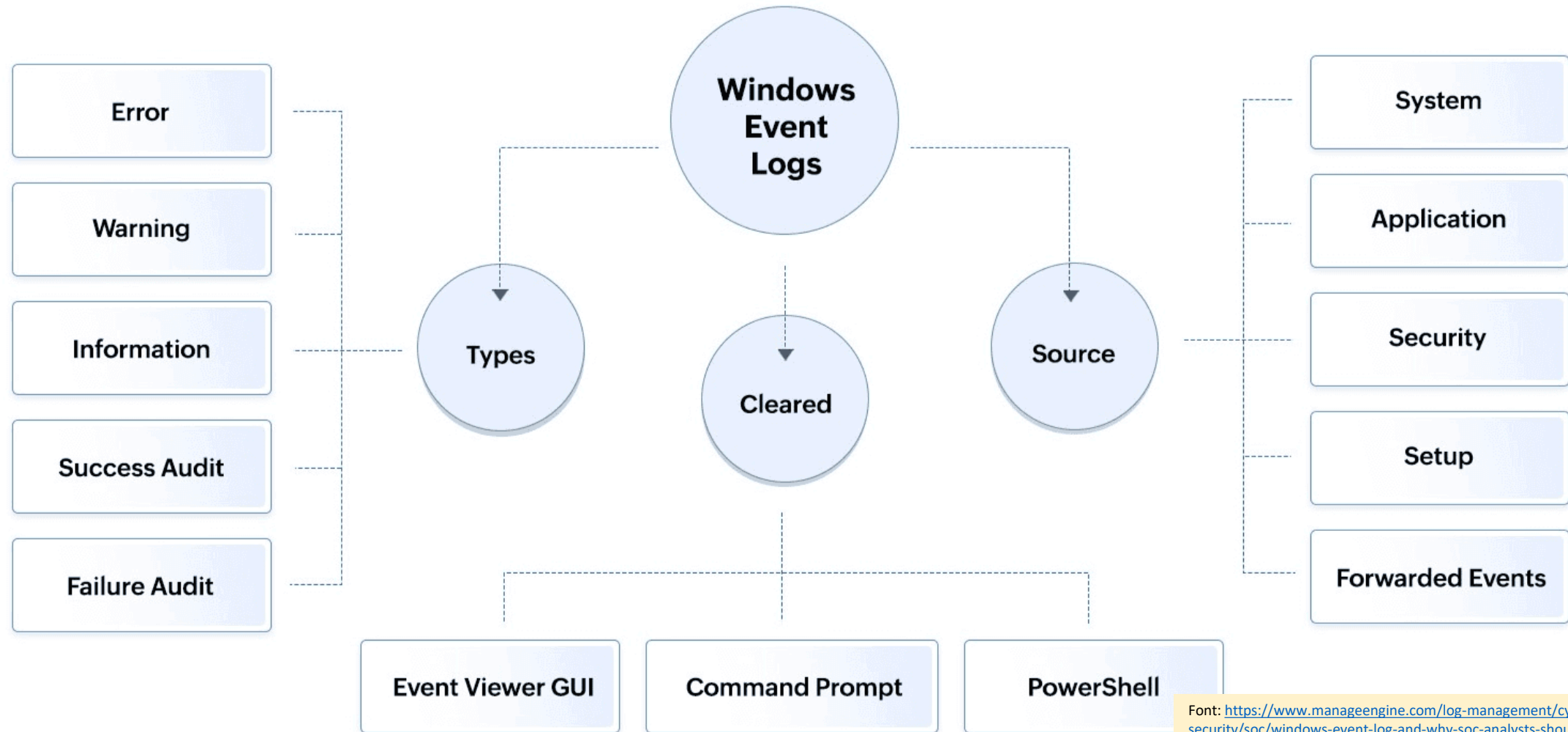
Administrar, analitzar i monitoritzar logs propis dels SO Windows



El servei EventLog

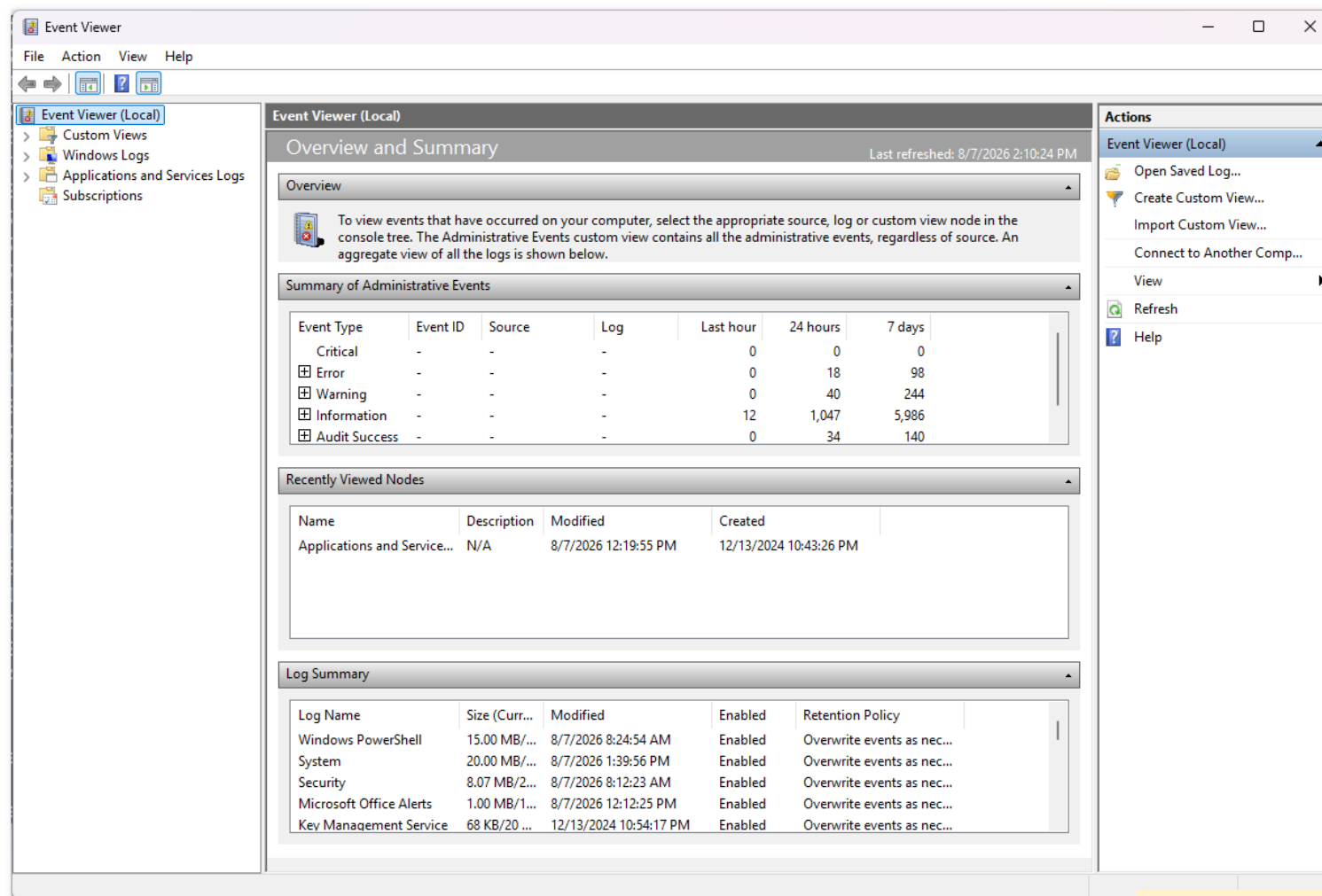
- El servei EventLog registra l'activitat en 3 categories bàsiques:
 - Security
 - System
 - Application
- Cadascuna d'aquestes categories és un fitxer `*.evtx`
 - Aquests fitxers tenen un format XML binari
 - Estan ubicats al directori `C:\Windows\System32\winevt\Logs`
- Des de Windows Vista hi ha mes categories (i fitxers ;-)
 - A Windows 11: entre 430 i 470 fitxers segons l'edició i els rols instal·lats

Categories basades en tipus i fonts



Font: <https://www.manageengine.com/log-management/cyber-security/soc/windows-event-log-and-why-soc-analysts-should-track-it.html>

Visor d'esdeveniments



eventvwr.exe / eventvwr.msc

Estructura d'un esdeveniment (camps)

- **Nivell** (per indicar la severitat)
 - Informació, Advertència, Error, Auditoria correcta/incorrecta
- **Data i hora** (és el timestamp de l'esdeveniment)
 - 2024-03-12 10:22:39
- **Origen** (el component o servei que el genera)
 - Microsoft-Windows-Security-Auditing
- **ID** de l'esdeveniment (codi que identifica el tipus de succés)
 - 4624, 4625, 4720, etc.
- **Categoria** de la tasca (és un subtipus dins l'origen)
 - Logon, User Account Management, etc.

Alguns esdeveniments clau per aquesta sessió

- ID 4624 / 4625
 - Inici de sessió correcte/fallit
- ID 4634 / 4647
 - Tancament de sessió
- ID 4720
 - Creació d'un usuari nou
- ID 4732
 - Usuari afegit a un grup local (per exemple "Administradors")
- ID 4688
 - Creació d'un procés

"Una seqüència 4720
→ 4732 en pocs
segons és un TTP
clàssic de
persistència/escalada
de privilegis"

Tipus d'inici de sessió (Logon Type)

- Tipus 2 (Interactive)
 - Consola local, teclat i pantalla
- Tipus 3 (Network)
 - Accés per xarxa (per exemple, a una carpeta compartida)
- Tipus 10 (RemoteInteractive)
 - Escriptori Remot (RDP)
- Tipus 4 (Batch)
 - Execució de tasques programades (scheduled tasks)
- Tipus 5 (Service)
 - Inici de sessió d'un servei del sistema

"El **Logon Type** és essencial per identificar accessos sospitosos i moviments laterals"

Esdeveniment 4624 (Inici de sessió correcte)

- Nivell:
 - Informació / Auditoria correcta
- LogonType
 - 2 = Interactive (consola local)
- Compte
 - IEUser (usuari que inicia la sessió)
- Logon ID
 - Identificador únic de la sessió
 - Permet correlació amb 4634 i 4647
- Procés origen
 - winlogon.exe (procés que inicia la sessió)

```
Event ID: 4624
TimeCreated: 2024-03-12 10:22:39
LogonType: 2
Account Name: IEUser
Account Domain: WIN10
Logon ID: 0x3e7
Process Name: C:\Windows\System32\winlogon.exe
Source Network Address: -
```

"Un 4624 no és només un 'inici de sessió correcte': és un conjunt de camps que expliquen **qui, com, quan i des d'on**"

Filtres XPath

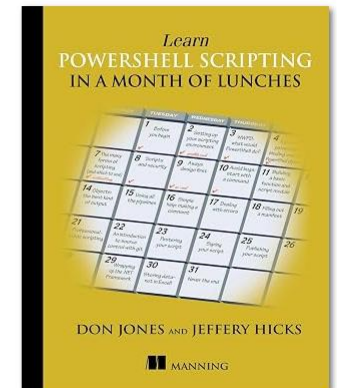
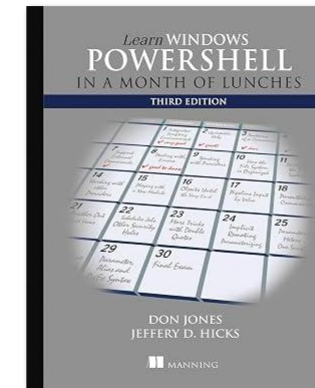
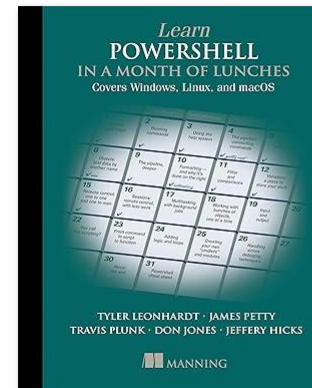
- **XPath** és un llenguatge de consulta que permet localitzar i manipular elements específics dins d'un XML
- Filtrar per ID
 - `*[System[ (EventID=4624) ]]`
- Filtrar per múltiples ID
 - `*[System[ (EventID=4720 or EventID=4732) ]]`
- Filtrar per un camp concret
 - `*[EventData[Data[@Name='LogonType']='10']]`

```
<Event>
  <System>
    <Provider Name="Microsoft-Windows-Security-Auditing"/>
    <EventID>4624</EventID>
    <TimeCreated SystemTime="2024-03-12T10:22:39Z"/>
  </System>
  <EventData>
    <Data Name="TargetUserName">IEUser</Data>
    <Data Name="LogonType">2</Data>
  </EventData>
</Event>
```

Cmdlets de PowerShell

- Estructura d'un cmdlet → **Verb-Noun**
 - Exemple: Get-WinEvent, Select-Object, etc.
- Alguns dels verbs més habituals:
 - Get (obtenir dades)
 - Set (configurar)
 - New (crear)
 - Remove (eliminar)
 - Select (seleccionar camps)
 - Start/Stop (iniciar/aturar)
- Alguns cmdlets clau per aquesta sessió
 - Get-WinEvent, Select-Object, Measure-Object, Where-Object, etc.

"PowerShell és consistent: si entens Verb-Noun, entens el 80% del llenguatge"



Ús de l'entorn Windows PowerShell



- Obrir Windows PowerShell
- Explorar l'entorn durant 5 min:
 - Buscar el cmdlet per obtenir ajuda
 - Tip: Utilitzar la tecla <TAB>
 - Obtenir ajuda sobre Get-WinEvent
 - Tip: -Online / -Examples
 - Obtenir ajuda sobre Objectes i Propietats
- Trobar els esdeveniments 7001 i 7002 del proveïdor Winlogon

Sysmon (System Monitor)

- Component de Sysinternals
- Amplia la telemetria a Windows (i també a Linux)
- Registra processos (1), connexions de xarxa (3), creació de fitxers (11), etc.
- Genera esdeveniments al canal Microsoft-Windows-Sysmon
- Permet detecció molt més rica que l'Event Log tradicional
- Es configura amb fitxers XML (per exemple SwiftOnSecurity)
- És útil per correlacionar TTPs de MITRE ATT&CK
 - Execució, persistència, moviment lateral

Event Log vs Sysmon

Aspecte	Event Log (Windows)	Sysmon
Origen	Integrat al SO	Sysinternals (add-on)
Canals	Security / System / Application	Microsoft-Windows-Sysmon
Detall	Limitat (per exemple 4624, 4625)	Molt alt (processos, xarxa, fitxers, DLLs, etc.)
Configuració	GPO / Audit policies	Fitxer XML personalitzat
Casos d'ús	Autenticació, canvis de comptes, errors del sistema	Detecció de TTPs, correlació avançada, hunting
Dificultat	Baixa	Mitjana (requereix config i manteniment)

Des de gener de 2022, existeix una versió per Linux:
<https://github.com/microsoft/SysmonForLinux>

Mostres de fitxers *.evtx

- Windows EVTX Samples ([sousseaden/EVTX-ATTACK-SAMPLES](https://sousseaden.github.io/EVTX-ATTACK-SAMPLES/))
 - 200+ fitxers organitzats per tècnica de MITRE ATT&CK
- EVTX to MITRE ATT&CK ([mdecrevoisier/EVTX-to-MITRE-Attack](https://mdecrevoisier.github.io/EVTX-to-MITRE-Attack/))
 - 270+ mostres mapejades a les tàctiques i tècniques de MITRE ATT&CK
- **DeepBlueCLI** ([sans-blue-team/DeepBlueCLI](https://sans-blue-team.github.io/DeepBlueCLI/))
 - Pocs fitxers però molt didàctics (inicis de sessió fallits, creació d'usuaris, etc.)
- Yamato Sample EVTX Repository ([Yamato-Security/hayabusa-sample-evtx](https://Yamato-Security.github.io/hayabusa-sample-evtx/))
 - Mostres pensades per provar regles de detecció Hayabusa/Sigma

Eines per tractar fitxers *.evtx des de Linux

- evtx (<https://github.com/omerbenamram/evtx>)
 - Analitzador ràpid (i segur) per al format Windows XML Event Log (EVTX)
 - CLI escrit en Rust; multi-plataforma
- **PowerShell 7** (<https://github.com/PowerShell/PowerShell>)
 - Eina d'automatització i configuració multiplataforma
 - Inclou un Shell de línia d'odres (pwsh)
 - No és el mateix que Windows PowerShell ;-)
- Zircolite (<https://github.com/wagga40/Zircolite>)
 - Eina de detecció basada en SIGMA independent per a EVTX, Auditd i Sysmon per a registres Linux

Exercicis dirigits

- Demo A: Llegir un fitxer sencer de DeepBlueCLI
 - Fitxer `new-user-security.evtx` de la carpeta `evtx`
 - `Get-WinEvent -Path` i `Format-Table`
- Demo B: Filtrar només els ID d'interès 4720 i 4732
 - Paràmetre `-FilterXPath` i `Select-Object`
- Demo C: Interpretar el resultat
 - Usuari creat (4720) i el seu nom (`IEUser`)
 - El mateix usuari afegit al grup d'Administradors
 - El interval de temps entre ambdós esdeveniments (1 segon)
- Demo D: Omplir la fitxa de resultat #1

Fitxa de resultat #1

- Fitxer analitzat: new-user-security.evtx
- Event ID(s) filtrats: 4720, 4732
- Usuari implicat: IEUser
- Timestamp dels esdeveniments:
 - 4720 (creació d'usuari) → 10/23/2013 6:22:39 PM
 - 4732 (afegit a grup Administradors) → 10/23/2013 6:22:40 PM
- Interval entre ambdós esdeveniments: 1 segon
- Patró/TTP: [T1136.001](#) (creació compte), [T1098.007](#) (modificació grup)
- Conclusió breu: Un interval d'1 segon és massa curt per un flux administratiu normal. Sembla un patró típic d'un atacant automatitzant la creació d'un compte amb privilegis

Treball autònom en parelles



- El treball s'ha d'entregar en **1 únic fitxer PDF per grup** amb:
 - Fitxes completades
 - Comandes executades i resultat
- El nom del fitxer ha de tenir aquest format:
 - `Lab2_grupXX_cognom1_cognom2.pdf`
- L'entrega es fa mitjançant el **Racó**
- Teniu fins a la **mitjanit** del següent dimarts o divendres per entregar

Analitzar fitxers *.evtx (2 punts)

- Descarregar aquests 2 fitxers addicionals de repositori [DeepBlueCLI](#) utilitzat en l'exercici anterior:
 - password-spray.evtx
 - smb-password-guessing-security.evtx
- Per a cada fitxer heu de:
 - Examinar-lo amb PowerShell
 - Identificar quin ID d'esdeveniment reflecteix els intents d'autenticació
 - Comptar quants esdeveniments hi ha en total de l'ID rellevant
 - Identificar el(s) compte(s) objectiu i, si apareix, el compte/origen de l'atac
 - Determinar el marc temporal (primer i darrer esdeveniment)
 - Classificar l'atac segons una tècnica de MITRE ATT&CK
 - Completar la **fitxa de resultat #2** de la **pàgina següent**

Fitxa resultat #2

- Fitxer analitzat:
- Event ID(s) filtrat(s):
- Nombre total d'esdeveniments:
- Compte(s) objectiu:
- Compte/origen (si és identificable):
- Primer esdeveniment (timestamp):
- Darrer esdeveniment (timestamp):
- Classificació MITRE ATT&CK:
- Conclusió breu (2 o 3 línies màxim):

Analitzar fitxers *.evtx (1 punt)

- Descarregar aquest fitxer addicional de repositori [DeepBlueCLI](#) utilitzat en l'exercici anterior:
 - `disablestop-eventlog.evtx`
- Per aquest fitxer, que mostra la manipulació del servei de logs de Windows, heu de:
 - Examinar-lo amb PowerShell
 - Identificar quins són els ID d'esdeveniment rellevants
 - Identificar comandes associades amb l'atac
 - Classificar l'atac segons una tècnica de MITRE ATT&CK
 - Conclusió breu (2 o 3 línies màxim)

Analitzar fitxers *.evtx (1 punt)

- Descarregar aquests fitxers addicionals de repositori [DeepBlueCLI](#) utilitzat en l'exercici anterior:
 - metasploit-psexec-native-target-system.evtx
 - metasploit-psexec-native-target-security.evtx
- Per aquests fitxers, que mostren un moviment lateral amb [PsExec](#) i [Metasploit](#), heu de:
 - Examinar-lo amb PowerShell
 - Identificar quins són els ID d'esdeveniment rellevants
 - Identificar comandes associades amb l'atac
 - Classificar l'atac segons una o varies tècniques de MITRE ATT&CK
 - Conclusió breu (2 o 3 línies màxim)

Analitzar fitxers *.evtx (1 punt)

- Descarregar aquest fitxer addicional de repositori [DeepBlueCLI](#) utilitzat en l'exercici anterior:
 - Powershell-Invoke-Obfuscation-encoding-menu.evtx
- Per aquest fitxer, que mostra l'ús de PowerShell ofuscat, heu de:
 - Examinar-lo amb PowerShell
 - Identificar quins són els ID d'esdeveniment rellevants
 - Identificar codi associat amb l'atac
 - Classificar l'atac segons una o varies tècniques de MITRE ATT&CK
 - Conclusió breu (2 o 3 línies màxim)

SOC WebQuest (Extra)

- Triar una plataforma de la llista (o una altra que conegueu):
 - **LetsDefend** (<https://letsdefend.io/>)
 - Simula un SOC real: reps alertes, investigues logs i decideixes com respondre a l'incident
 - **HackTheBox** (<https://www.hackthebox.com/>)
 - Els reptes "Sherlocks" et posen a investigar logs i fitxers EVTX reals d'un atac ja consumat
 - **TryHackMe** (<https://tryhackme.com/>)
 - Ruta guiada "SOC Level 1", amb sales pas a pas i *flags* per validar cada troballa
 - **CyberDefenders** (<https://cyberdefenders.org/>)
 - Reptes CTF de Blue Team centrats en anàlisi forense de logs i fitxers EVTX reals
- Uniu-vos al pla gratuït de la plataforma que més us agradi
 - Tip: Podeu fer servir un àlies de correu de [SimpleLogin](#) o similar ;-)
- Exploreu-la per trobar algun exercici relacionat amb la gestió de logs